

NIST SP 800-90A ("SP" stands for "special publication") is a publication by the National Institute of Standards and Technology with the title Recommendation for Random Number Generation Using Deterministic Random Bit Generators. The publication contains the specification for three allegedly cryptographically secure pseudorandom number generators for use in cryptography: Hash DRBG (based on hash functions), HMAC DRBG (based on HMAC), and CTR DRBG (based on block ciphers in counter mode). Earlier versions included a fourth generator, Dual_EC_DRBG (based on elliptic curve cryptography). Dual_EC_DRBG was later reported to probably contain a kleptographic backdoor inserted by the United States National Security Agency (NSA).

As a work of the US Federal Government, NIST SP 800-90A is in the public domain and freely available.

History

The predecessor to NIST SP 800-90A was published by the National Institute of Standards and Technology in June 2006 as NIST SP 800-90 with the title Recommendation for Random Number Generation Using Deterministic Random Bit Generators. This 2006 publication contains the specification for four allegedly cryptographically secure pseudorandom number generators for use in cryptography: Hash_DRBG (based on hash functions), HMAC_DRBG (based on HMAC), CTR_DRBG (based on block ciphers in counter mode), and Dual_EC_DRBG (based on elliptic curve cryptography).

In March 2007, the publication NIST SP 800-90 Revised (800-90R) with the same title replaced the earlier version. Besides some minor textual clarification, there was a substantial change in the form of an additional step for Dual_EC_DRBG to provide backtracking resistance.

In January 2012, NIST SP 800-90A was published to replace NIST SP 800-90 Revised. The change notes mention that most of the revision was finished in August 2008, and that the recommendation was developed in concert with ANSI X9.82-3. Non-algorithmic changes

included addition of explanations, definitions, and a rule against self-reseeding. The instantiation function for Dual_EC_DRBG was substantially revised; the appendix dedicated to justifying this DRBG received a new paragraph. The new hash functions from FIPS 180-4 were added in the discussion of hash-based

In June 2015, NIST 800-90A Revision 1 (800-90Ar1) was released. The most notable change is the removal of the dubious Dual_EC_DRBG algorithm.

Brief history of doubts cast on Dual_EC_DRBG

Dual_EC_DRBG was not first introduced to the public in NIST SP 800-90 of 2006. It was seen in a 2004 draft of ANSI X9.82-3 as well as the official version of ISO/IEC 18031:2005. Its flaws were first proven in March 2006, when Kristian Gjølsteen published a method to predict the bias in the version found in the December 2015 draft of NIST SP 800-90. However, the subsequent publication in June 2006 did not address this flaw.

In 2007, Dan Shumow and Niels Ferguson provided a much stronger attack with the ability to recover the entire internal state with just 32 bytes of output, predicting all its future output. The unexplained constants in Dual_EC_DRBG were hypothesized to act like a public key; an attacker would use a different set of numbers (analogous to a private key) to mount the attack. Shumow and Ferguson were not able to recover the NSA's key, but they were able to construct their own pair of keys for a demonstration. In November 2007, Bruce Schneier commented on the "strange" nature of the history of this random number generator and described the Shumow and Ferguson presentation in more accessible terms.

Attention to Dual_EC_DRBG was raised again in September 2013 in light of an National Security Agency memo found in Edward Snowden's leak claiming a kleptographic backdoor. Retroactive search of patents and papers associated with this DRBG revealed that the general technique used was already described in two 1997 papers. Furthermore, a 2005 patent describes the exact technique used in the backdoor as well as a method to neutralize it.

However, the subtle formulation used in the standard meant that FIPS 140-2 compliance would preclude the use of any neutralization technique.

NIST disavowed the use of Dual_EC_DRBG to RSA some time before February 26, 2014. On April 21, 2014, NIST withdrew Dual_EC_DRBG from its draft guidance on random number generators recommending that "current users of Dual_EC_DRBG transition to one of the three remaining approved algorithms as quickly as possible". This draft would become formalized as NIST SP 800-90A Revision 1 in June 2015.

Security analysis

NIST claims that each of the four (revised to three) DRBGs are "backtracking resistant" and "prediction resistant". The former is the common notion of "forward secrecy" of PRNGs: in the event of a state compromise, the attacker cannot recover historical states and outputs. The latter means that if the state is compromised and subsequently re-seeded with sufficient entropy, security is restored.

Dual_EC_DRBG

An attempted security proof for Dual_EC_DRBG states that it requires three problems to be mathematically hard in order for Dual_EC_DRBG to be secure: the decisional Diffie-Hellman problem, the x-logarithm problem, and the truncated point problem. The decisional Diffie-Hellman problem is widely accepted as hard. The x-logarithm problem is not widely accepted as hard. Some evidence is shown that this problem is hard but that evidence is not conclusive. The security proof is therefore questionable and would be proven invalid if the x-logarithm problem is shown to be efficiently solvable. The truncated point problem requires enough bits to be truncated from the point selected by Dual_EC_DRBG to make it indistinguishable from a truly random number. However, the truncation of 16 bits, the default specified by the Dual_EC_DRBG standard, has been shown to be insufficient to make the

output indistinguishable from a true random number generator and therefore invalidates Dual_EC_DRBG's security proof when the default truncation value is used.

Backdoor in Dual_EC_DRBG

As part of the Bullrun program, NSA has inserted backdoors into cryptography systems. One such target was suggested in 2013 to be Dual_EC_DRBG. The NSA accomplished this by working during the standardization process to eventually become the sole editor of the standard. In getting Dual_EC_DRBG accepted into NIST SP 800-90A, NSA cited prominent security firm RSA Security's usage of Dual_EC_DRBG in their products. However, RSA Security had been paid \$10 million by NSA to use Dual_EC_DRBG as default, in a deal that Reuters describes as "handled by business leaders rather than pure technologists". As the \$10 million contract to get RSA Security to use Dual_EC_DRBG was described by Reuters as secret, the people involved in the process of accepting Dual_EC_DRBG into NIST SP 800-90A were presumably not made aware of this obvious conflict of interest. This might help explain how a random number generator later shown to be inferior to the alternatives (in addition to the back door) made it into the NIST SP 800-90A standard.

The potential for a backdoor in Dual_EC_DRBG had already been documented by Dan Shumow and Niels Ferguson in 2007, but continued to be used in practice by companies such as RSA Security until the 2013 revelation. Given the known flaws in Dual_EC_DRBG, there have subsequently been accusations that RSA Security knowingly inserted a NSA backdoor into its products. RSA has denied knowingly inserting a backdoor into its products.

Following the NSA backdoor revelation, NIST has reopened the public vetting process for the NIST SP 800-90A standard. A revised version of NIST SP 800-90A that removes Dual_EC_DRBG was published in June 2015.

Hash_DRBG and HMAC_DRBG

Hash_DRBG and HMAC_DRBG have security proofs for a single call to generate pseudorandom numbers. The paper proving the security of Hash_DRBG and HMAC_DRBG does cite the attempted security proof for Dual_EC_DRBG used in the previous paragraph as a security proof to say that one should not use CTR_DRBG because it is the only DRBG in NIST SP 800-90A that lacks a security proof.

HMAC_DRBG also has a machine-verified security proof. The thesis containing the machine-verified security proof also proves that a compromise of a properly-implemented instance of HMAC_DRBG does not compromise the security of the numbers generated before the compromise.

Woodage and Shumow (2019) analyze the NIST schemes in more detail; specifically, they provide security proofs that take into account the initial seed generation and reseeding, which have not been analyzed at all before. Under random oracle model and assuming an oracle-independent entropy source:

Hash_DRBG is robust in the sense of Dodis et al., i.e. meeting both of the NIST security claims. HMAC_DRBG is robust given two conditions: it must be called with additional input entropy, and said entropy must satisfy additional conditions. All NIST-approved entropy sources satisfy these "additional conditions".

HMAC_DRBG is not forward-secure when called without additional input.

CTR_DRBG

CTR_DRBG has been shown to have a theoretical imperfection when used with certain parameters because cryptographers did not consider the block size of the cipher when designing this pseudorandom number generator. CTR_DRBG appears secure and indistinguishable from a true random source when AES is used as the underlying block cipher and 112 bits are taken from this pseudorandom number generator. When AES is used as the

underlying block cipher and 128 bits are taken from each instantiation, the required security level is delivered with the caveat that a 128-bit cipher's output in counter mode can be distinguished from a true random number generator. When AES is used as the underlying block cipher and more than 128 bits are taken from this pseudorandom number generator, then the resulting security level is limited by the block size instead of the key size and therefore the actual security level is much less than the security level implied by the key size. CTR_DRBG is also shown to fail to deliver the expected security level whenever Triple DES is used because its 64-bit block size is much less than the 112-bit key size used for Triple DES. There is currently no known method to exploit this issue when AES is used.

Key erasure

The NIST CTR_DRBG scheme erases the key after the requested randomness is output by producing additional randomness to replace the key. This is wasteful from a performance perspective, but does not immediately cause issues with forward secrecy. However, realizing the performance implications, the NIST recommends an "extended AES-CTR-DRBG interface" for its Post-Quantum Cryptography Project submissions. This interface allows multiple sets of randomness to be generated without intervening erasure, only erasing when the user explicitly signals the end of requests. As a result, the key could remain in memory for an extended time if the "extended interface" is misused. An alternative proposed by Bernstein is to produce randomness to replace the key before the requested randomness is output, as done in "fast-key-erasure" RNGs.

The security bounds reported by Campagna (2006) does not take into account any key replacement procedure.

Woodage and Shumow (2019) provides a draft analyses of the situation mentioned by Bernstein, i.e. state leakage assuming large amounts of randomness (next) generated between re-keying (final).

See also

NIST SP 800-90B

NIST SP 800-90C

References

=== Version history ===